HƯỚNG DẪN TÁI HIỆN PoC

Tính năng sửa điểm — miniLMS

Thực hiện bằng Burp Suite · So sánh nhánh lỗi và nhánh đã sửa

Mục	Nội dung
Hệ thống	miniLMS — http://127.0.0.1:8888
Nhánh lỗi	sua-diem-vuln
Nhánh đã sửa	sua-diem-fixed
Tài khoản	admin@lms.test / an.gv@lms.test — mật khẩu Lms@2026
Công cụ	Burp Suite (Proxy + Repeater), trình duyệt của Burp, psql
Mục tiêu	Chụp ảnh PoC cho V01 (lost update), V02 (500), V03 (dữ liệu sai)

1. Chuẩn bị môi trường

1. Mở terminal tại thư mục dự án, chạy: git checkout sua-diem-vuln
2. Chạy run.bat (PostgreSQL + web) và đăng nhập thử một tài khoản.
3. Mở Burp Suite → Proxy → Intercept is off; bật trình duyệt của Burp.
4. Truy cập http://127.0.0.1:8888, đăng nhập admin@lms.test / Lms@2026.
5. Chụp lại màn hình terminal + trình duyệt làm ảnh môi trường.

Lấy ID bản ghi để tấn công

Mở terminal thứ hai và chạy (mật khẩu PostgreSQL chỉ dùng cho dev):

```
$env:PGPASSWORD='lms_dev_2026'
& 'D:\Setup\Postgre SQL\bin\psql.exe' -U lms_dev -d lms_dev -c "
  select id, assignment_id, student_id, score, feedback from submissions order by id;
  select id, quiz_id, student_id, score, passed, status from quiz_attempts order by id;"
```

Ghi lại submission_id và attempt_id; các bước dưới dùng <sid>, <aid>.

Tạo dữ liệu mẫu nếu DB trống

```
insert into submissions (assignment_id, student_id, text, submitted_at, score, feedback,
graded_at)
values (1, 'u4', 'Bài làm mẫu', now(), 5, 'Tốt', now());

insert into quiz_attempts (quiz_id, student_id, started_at, submitted_at, score, passed,
status)
values (1, 'u5', now(), now(), 5, false, 'SUBMITTED');
```

2. Cấu hình Burp Suite

1. Proxy → Options → Proxy listeners: thêm 127.0.0.1:8080 (nếu chưa có).
2. Proxy → Intercept: để Off trong lúc thao tác, dùng HTTP history để bắt request.
3. Mở trình duyệt Burp: tab Proxy → Open browser.

4. Trong trình duyệt Burp, truy cập http://127.0.0.1:8888/login và đăng nhập.
5. Thao tác bình thường trên web; mọi request hiện ở Proxy → HTTP history.
6. Chuột phải request cần phân tích → Send to Repeater (Ctrl+R).
7. Ở Repeater, bấm Send (Ctrl+Space hoặc nút Send) và chụp tab này.

Vì web chạy HTTP nội bộ nên không cần cài CA certificate cho các bước này.

3. PoC V01 — Hai người sửa điểm, người sau ghi đè

Mục	Nội dung
Endpoint	POST /admin/grades/assignment/<sid>/adjust
Body	score=<điểm>&feedback=<nhận xét> (nhánh lỗi không có version)
Kỳ vọng lỗi	Cả hai lần gửi đều 302; DB chỉ còn điểm của lần sau
Kỳ vọng sau sửa	Lần 1: 302; lần 2: 409 Conflict; DB giữ điểm lần 1

Các bước tạo PoC

1. Đăng nhập admin, mở /admin/grades, cuộn tới Assignment Submissions.
2. Ở dòng của <sid>, nhập điểm 9 và bấm Lưu (để Burp bắt request).
3. Vào Proxy → HTTP history, tìm POST /admin/grades/assignment/<sid>/adjust.
4. Chuột phải → Send to Repeater. Đây là request của "người A".
5. Bấm Send lần 1 → chụp ảnh (302). Kiểm tra DB: score = 9.
6. Không sửa gì, bấm Send lần 2 (mô phỏng "người B" giữ dữ liệu cũ).
7. Nhánh lỗi: vẫn 302 và DB thành điểm mới. Chụp ảnh mâu thuẫn.
8. Chuyển sang nhánh sua-diem-fixed, lặp lại: lần 2 phải trả 409.

Trên nhánh đã sửa, request có thêm trường version (hidden input); Repeater giữ nguyên version cũ nên lần gửi thứ hai bị từ chối.

Request mẫu (nhánh lỗi)

```
POST /admin/grades/assignment/<sid>/adjust HTTP/1.1
Host: 127.0.0.1:8888
Cookie: lms_token=<token>
Content-Type: application/x-www-form-urlencoded

score=9&feedback=T%E1%BB%91t
```

Request mẫu (nhánh đã sửa)

```
POST /admin/grades/assignment/<sid>/adjust HTTP/1.1
Host: 127.0.0.1:8888
Cookie: lms_token=<token>
Content-Type: application/x-www-form-urlencoded

score=9&feedback=T%E1%BB%91t&version=1
```

Response cần chụp

```
NHÁNH LỖI (cả 2 lần):  HTTP/1.1 302 FOUND
  Location: /admin/grades

NHÁNH ĐÃ SỬA:
  Lần 1: HTTP/1.1 302 FOUND
  Lần 2: HTTP/1.1 409 CONFLICT
  Body chứa: "Điểm đã được người khác cập nhật. Vui lòng tải lại trang."
```

Kiểm tra DB để chụp kèm

```
select id, score, feedback from submissions where id = <sid>;
-- Nhánh lỗi sau 2 lần: score = 9 (không phân biệt ai thắng)
-- Nhánh sửa: score = 9, version = 2
```

Cách 2 — hai trình duyệt (nếu muốn minh hoạ 2 người)

- Đăng nhập cùng tài khoản ở cửa sổ thường và cửa sổ ẩn danh (2 cookie khác nhau).
- Cả hai mở /admin/grades; A lưu 9; B lưu 2. Trên nhánh lỗi, A tải lại thấy 2.
- Trên nhánh sửa, B nhận trang 409 và điểm vẫn là 9.

4. PoC V02 — Chỉnh điểm quiz làm máy chủ trả 500

Mục	Nội dung
Endpoint	POST /admin/grades/quiz/<aid>/adjust
Body	score=8 (nhánh sửa thêm &version=1)
Kỳ vọng lỗi	HTTP 500, traceback AttributeError: 'QuizAttempt' object has no attribute 'quiz'
Kỳ vọng sau sửa	HTTP 302, DB score=8, passed=True

1. Mở /admin/grades, cuộn tới Quiz Attempts.
2. Nhập điểm 8 ở dòng <aid> và bấm Lưu.
3. Burp bắt POST /admin/grades/quiz/<aid>/adjust → Send to Repeater.
4. Bấm Send; nhánh lỗi trả 500 kèm traceback (debug đang bật).
5. Chụp toàn bộ trang 500, đặc biệt dòng AttributeError và tên tệp admin.py.
6. Chuyển nhánh fixed, lặp lại: 302, DB cập nhật đúng.

```
POST /admin/grades/quiz/<aid>/adjust HTTP/1.1
Host: 127.0.0.1:8888
Cookie: lms_token=<token>
Content-Type: application/x-www-form-urlencoded

score=8
```

Ảnh cần chụp

- Response 500 + traceback (nhánh lỗi).
- Response 302 + DB score=8, passed=True (nhánh sửa).
- psql: select id, score, passed from quiz_attempts where id=<aid>;

5. PoC V03 — Điểm ngoài miền và mất nhận xét

Mục	Nội dung
Endpoint	POST /admin/grades/assignment/<sid>/adjust
Body	score=99 (không gửi feedback)
Kỳ vọng lỗi	302; DB score=99, feedback bị xoá thành rỗng
Kỳ vọng sau sửa	302 kèm flash lỗi; DB không đổi, feedback giữ nguyên

1. Đảm bảo bài nộp <sid> có score=5, feedback="Tốt" (xem mục 1).
2. Bắt request chỉnh điểm ở /admin/grades → Send to Repeater.
3. Sửa body thành score=99, xoá dòng feedback; bấm Send.
4. Nhánh lỗi: 302, DB score=99 và feedback rỗng. Chụp psql + response.
5. Nhánh sửa: 302 nhưng DB vẫn 5/"Tốt"; mở lại /admin/grades thấy banner lỗi.
6. Gửi tiếp score=7 (không feedback): nhánh sửa giữ "Tốt", nhánh lỗi xoá tiếp.

```
POST /admin/grades/assignment/<sid>/adjust HTTP/1.1
Host: 127.0.0.1:8888
Cookie: lms_token=<token>
Content-Type: application/x-www-form-urlencoded

score=99
```

Ảnh cần chụp

- Repeater body score=99 và response 302 (nhánh lỗi).
- psql: score=99, feedback='' (nhánh lỗi).
- Trang /admin/grades hiện "Điểm phải nằm trong khoảng 0–10.0." (nhánh sửa).
- psql: score=5, feedback='Tốt' (nhánh sửa).

6. Checklist ảnh PoC

STT	Ảnh	Nhánh	Nội dung
1	Môi trường	vuln	Terminal run.bat + Burp + trang login
2	HTTP history	vuln	Danh sách request POST sửa điểm
3	Repeater lần 1	vuln	Request/response 302
4	Repeater lần 2	vuln	Vẫn 302, DB bị ghi đè
5	psql trước/sau	vuln	score thay đổi, feedback rỗng
6	Repeater 500	vuln	V02 traceback AttributeError
7	Repeater lần 2	fixed	409 Conflict, body thông báo
8	psql sau	fixed	score giữ 9, version=2
9	Trang lỗi	fixed	Banner "Điểm đã được người khác cập nhật"
10	Repeater V02	fixed	302 thay vì 500
11	psql V03	fixed	score=5, feedback='Tốt'

Mỗi ảnh nên thấy rõ: URL, request body, status code, và (nếu được) kết quả psql cùng màn hình.

7. Mẹo chụp PoC rõ ràng

- Bật "Follow redirects" khi cần xem thông báo flash ở trang đích; tắt khi cần chụp 302/409.
- Trong Repeater, bôi đậm/đánh dấu dòng score và version; chụp cả tab Response.
- Đặt psql cạnh Burp và chụp chung một ảnh để thấy request ↔ dữ liệu.
- Ghi rõ tên nhánh trong ảnh (tiêu đề cửa sổ terminal hoặc chú thích).
- Với V01, chụp thêm tab HTTP history chứng minh hai request giống nhau.

Phụ lục — Lệnh reset dữ liệu giữa các lần demo

```
update submissions set score=5, feedback='Tốt'
where assignment_id=1 and student_id='u4';

update quiz_attempts set score=5, passed=false, status='SUBMITTED'
where id=<aid>;

-- Xem lại
select id, score, feedback from submissions order by id;
select id, score, passed, status from quiz_attempts order by id;
```

Lưu ý: nhánh sua-diem-vuln không có cột version trong model; DB có thể vẫn còn cột này từ lần chạy nhánh fixed — không ảnh hưởng PoC.